

ET 8202 :

INTRODUCTION TO

INFORMATION

SYSTEM SECURITY

ET 8202: INTRODUCTION TO IS SECURITY

LECTURE 01

INTRODUCTION TO IS SECURITY

Date: 03/11/2023

ESSENTIAL TERMINOLOGIES

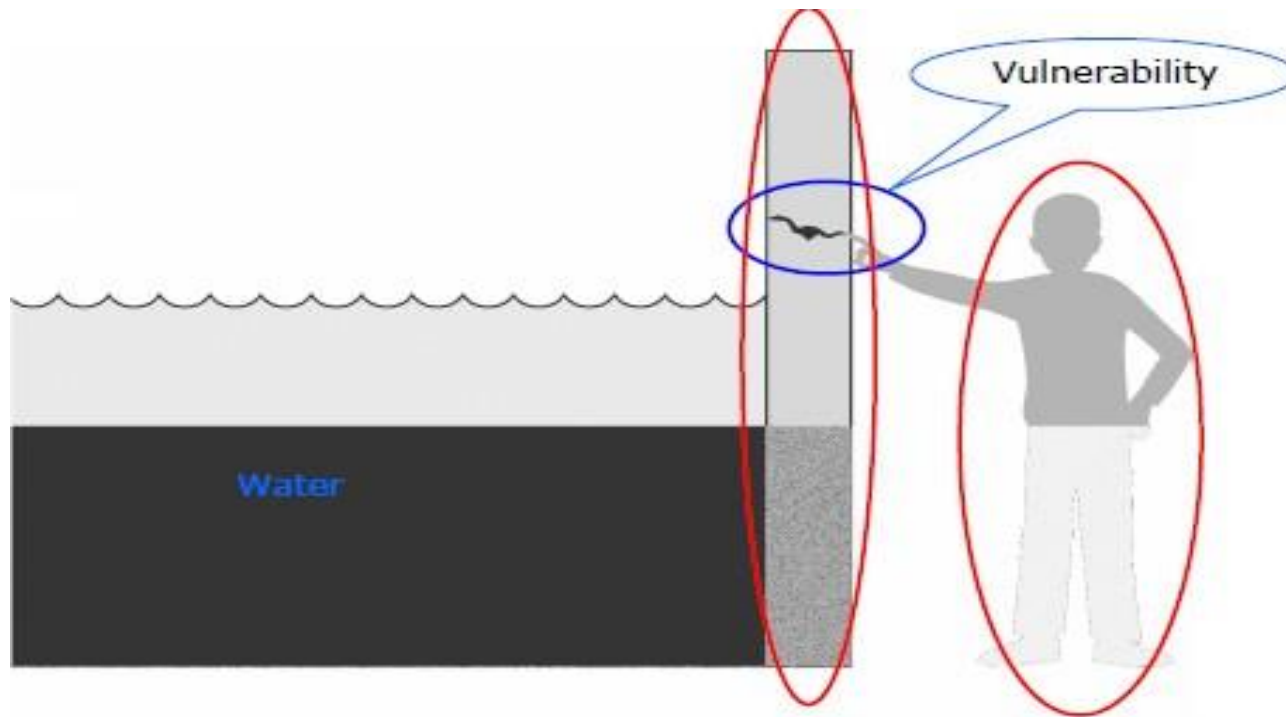
- **Security:** A state of well-being of information and infrastructure in which the possibility of **theft, tempering, and disruption of information and services** is kept low or tolerable.
- **Vulnerability:** Existence of a weakness, design, or implementation error that can lead to an unexpected and undesirable event compromising the security of the system.

ESSENTIAL TERMINOLOGIES

- **Threat:** An action or event that might compromise security. A threat is a potential violation of security.
- **Exploit:** A defined way to breach the security of an IT system through vulnerability.
- **Attack:** Exploitation of vulnerability.
- **Control:** Is an action, procedure or technique that removes or reduces the vulnerabilities.

ESSENTIAL TERMINOLOGIES

- A **threat** is blocked by **control** of a **vulnerability**.



- **Example:** The finger of the man can control a water leak.

ESSENTIAL TERMINOLOGIES

- **Information security:** Is the practice of defending information from unauthorized access, use, disclosure, disruption, modification, inspection, recording or destruction.
- **Data security:** Data security is the means of ensuring that data is kept safe from corruption and that access to it is suitably controlled.

ESSENTIAL TERMINOLOGIES

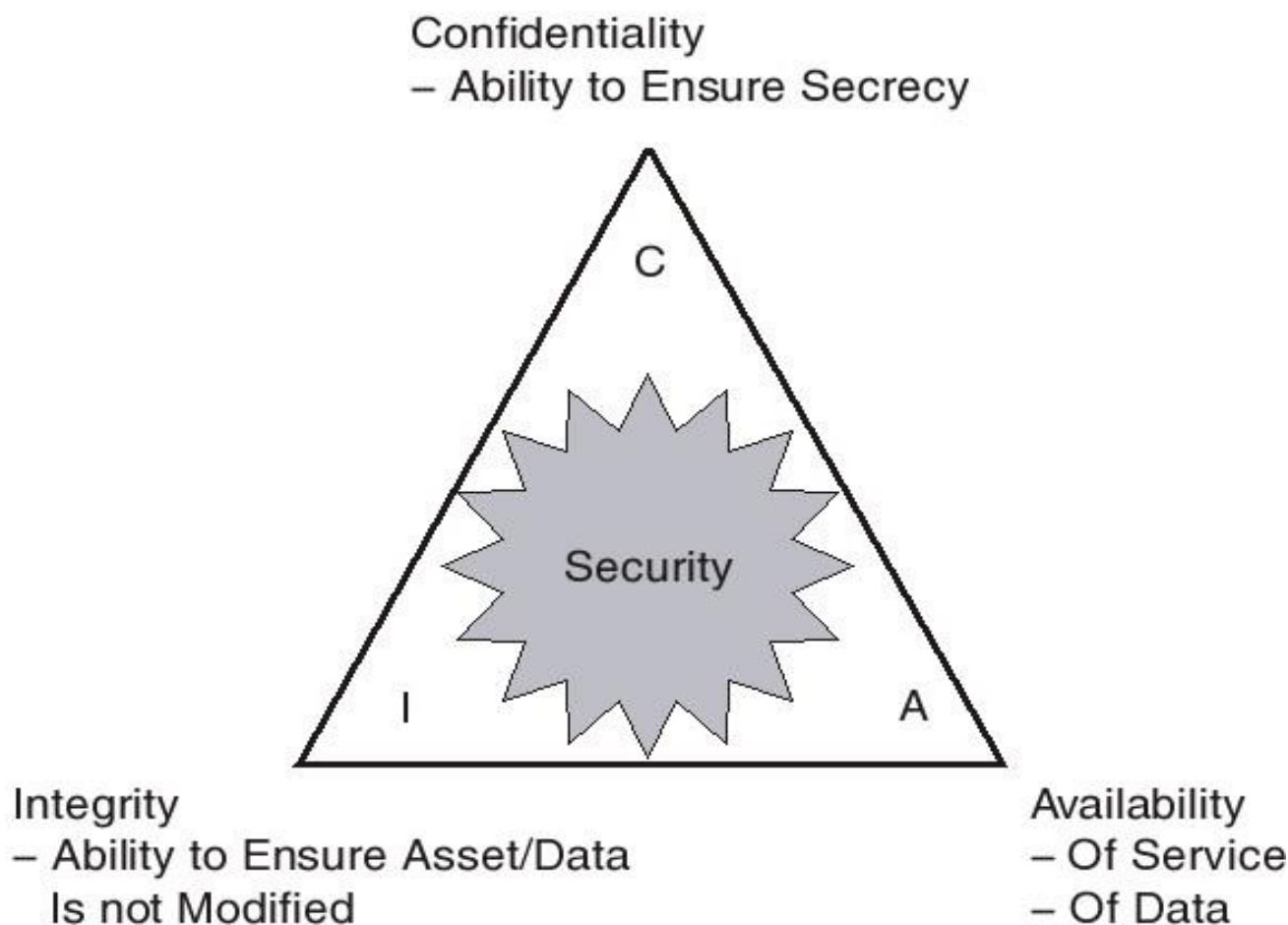
- **Network Security:** Protect the network and the network-accessible resources from unauthorized access, consistent and continuous monitoring and measurement of its effectiveness
- **IT Security:** IT Security is information security when applied to technology. Sometimes referred to as **computer security**.

ESSENTIAL TERMINOLOGIES

- **Computer Security:** Is defined as the protection afforded to an automated information system in order to attain the applicable objectives of preserving the **Confidentiality**, **Integrity** and **Availability** of information system resources (includes hardware, software, firmware, information/data, and telecommunications)

CIA Triad

Security Triad Principles



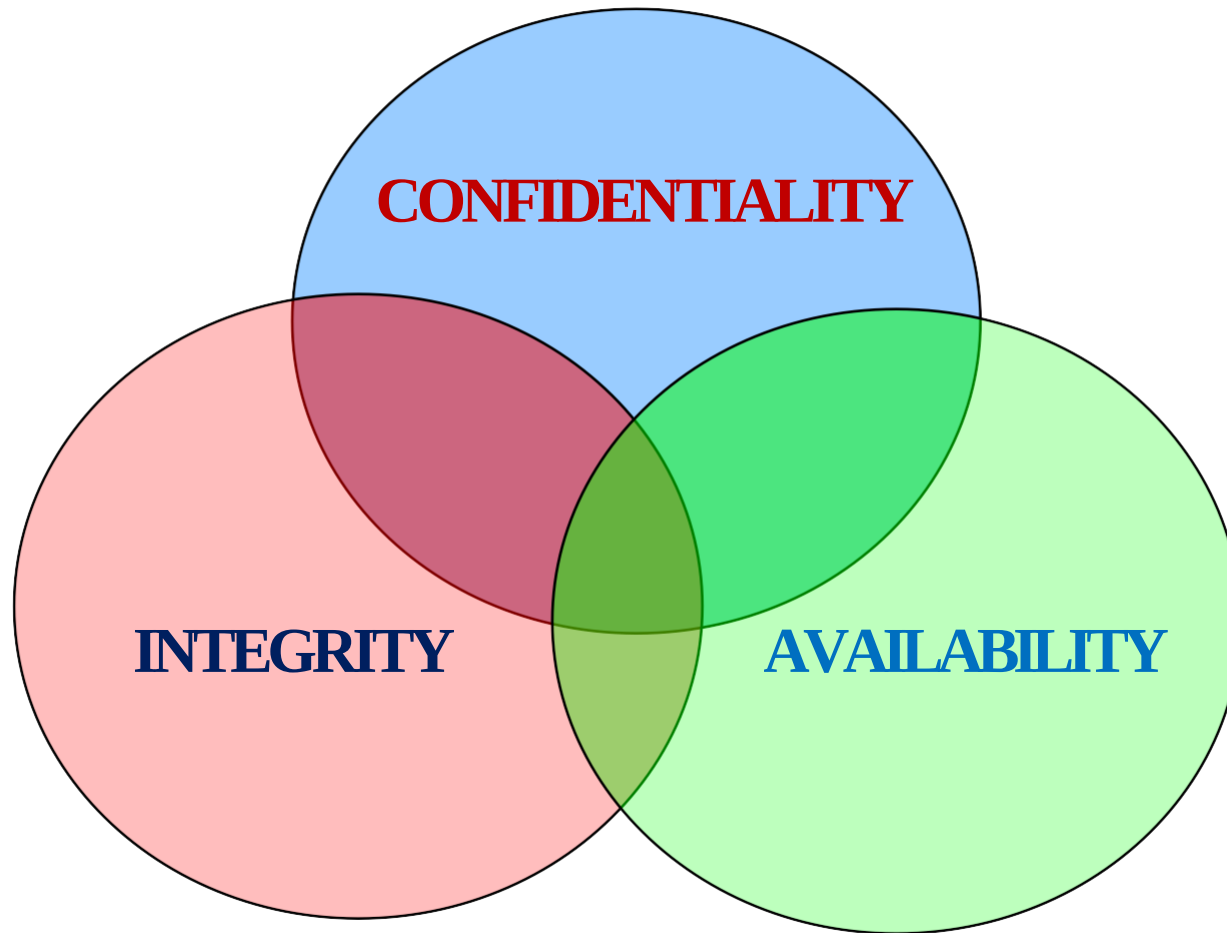
KEY OBJECTIVES (1)

- **Confidentiality:** Assurance that the information is accessible only to those **authorized to have access**.
 - ✓ **Data Confidentiality:** Information not disclosed to unauthorized individuals.
 - ✓ **Privacy:** Individuals control how their information is collected, stored, shared.

KEY OBJECTIVES (2)

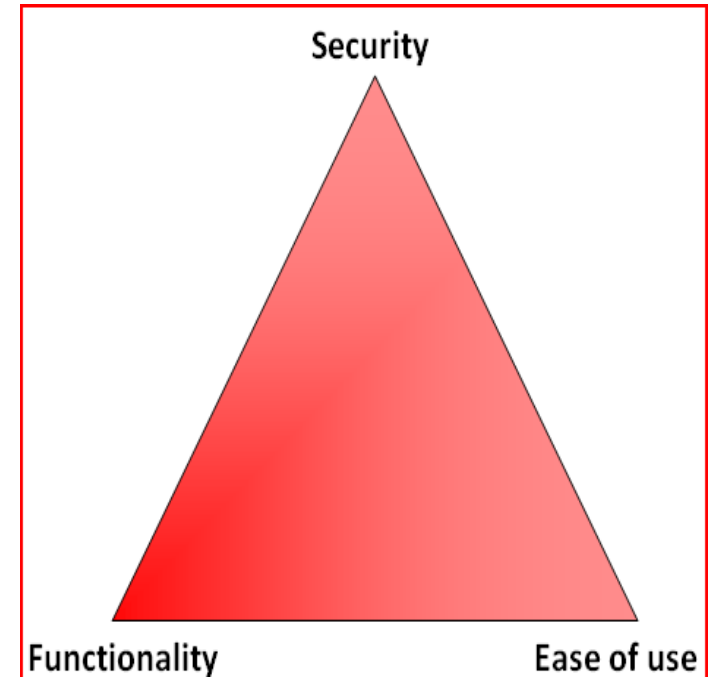
- **Integrity:** The **trustworthiness of data** of resources in terms of preventing improper and unauthorized changes. Assurance that information can be relied upon to be sufficiently accurate for its purpose.
 - ✓ **Data Integrity**
 - ✓ **System Integrity**
- **Availability:** Assurance that the systems are accessible when **required by the authorized users**.
 - ✓ Service not denied to authorized users.

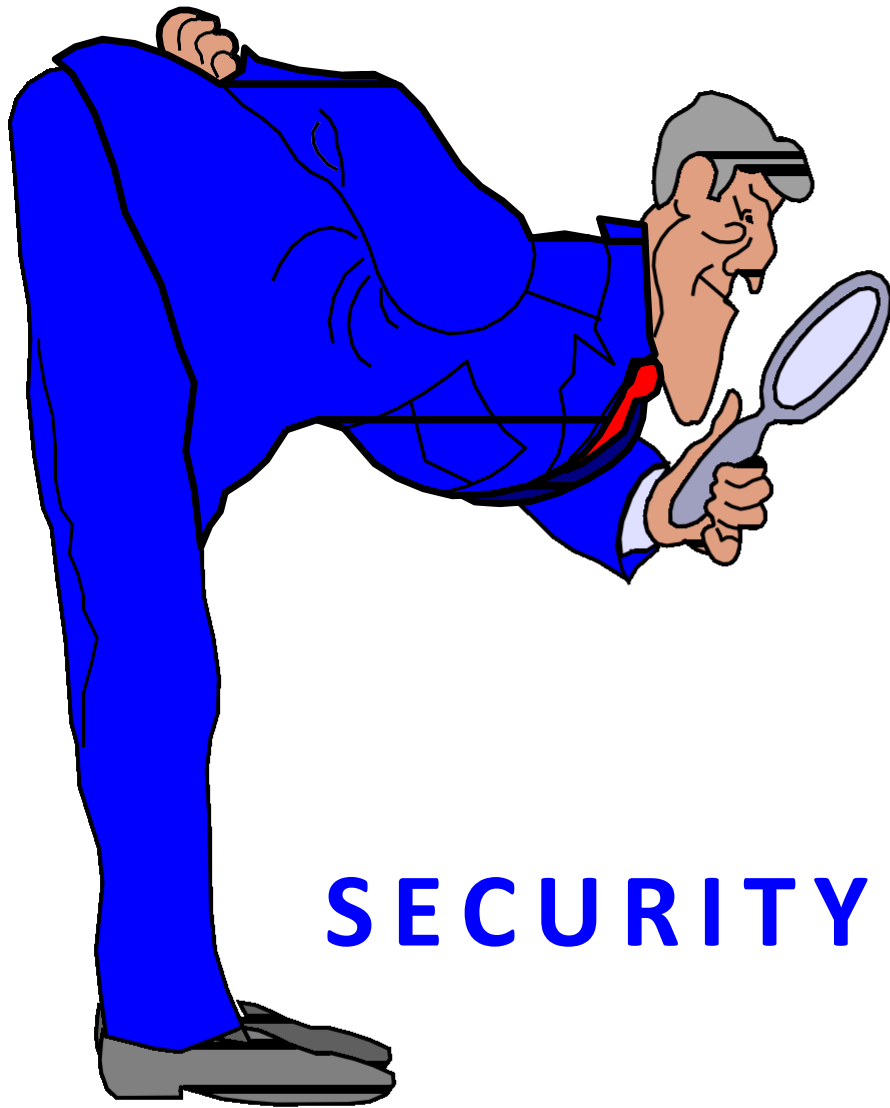
SECURITY GOALS



The Security, Functionality and Usability triangle

- Level of security in any system can be defined by the strength of three components:
 1. **Functionality:** Features
 2. **Usability:** GUI
 3. **Security:** Restrictions
- Moving towards security means less functionality and usability.





OSI SECURITY ARCHITECTURE

SERVICES, MECHANISMS, ATTACKS (OSI SECURITY ARCHITECTURE)

- International Telecommunications Union (ITU) is a United Nations sponsored agency that develops standards relating to telecommunications and to Open system Interconnection (**OSI**)
- ITU-T X.800 “Security Architecture for OSI” defines a systematic way of defining and providing security requirements.
- The document defines security attacks, mechanisms, and services, and the relationships among these categories.

SERVICES, MECHANISMS, ATTACKS (OSI SECURITY ARCHITECTURE)

- The OSI security architecture focuses on
 1. Security **Attacks**,
 2. Security **Mechanisms**
 3. Security **Services**

SERVICES, MECHANISMS, ATTACKS (OSI SECURITY ARCHITECTURE)

Definition

- The **OSI Security Architecture** is a framework that provides a systematic way of defining the requirements for security and characterizing the approaches to satisfying those requirements. The document defines security **attacks**, **mechanisms**, and **services**, and the relationships among these categories.

SERVICES, MECHANISMS, ATTACKS (OSI SECURITY ARCHITECTURE)

1. **Security Attacks:** Any action that compromises the security of information owned by an organization.
2. **Security Mechanism:** Any process that is designed to detect, prevent or recover from a security attacks. E.g., encryption algorithm, digital signatures, and authentication protocols
3. **Security Services:** The services are intended to counter security attacks, and they make the use of one or more security mechanisms to provide the services. E.g., authentication, access control, data confidentiality, data integrity, nonrepudiation, and availability

(1) THREAT VS. ATTACK

- **Threat:** A potential for violation of security, which exists when there is a circumstance, capability, action, or event that could breach security and cause harm. That is, a threat is a possible danger that might exploit a vulnerability.
- **Attack:** An assault on system security that derives from an intelligent threat; that is, an intelligent act that is a deliberate attempt (especially in the sense of a method or technique) to evade security services and violate the security policy of a system.

SECURITY ATTACKS/THREATS

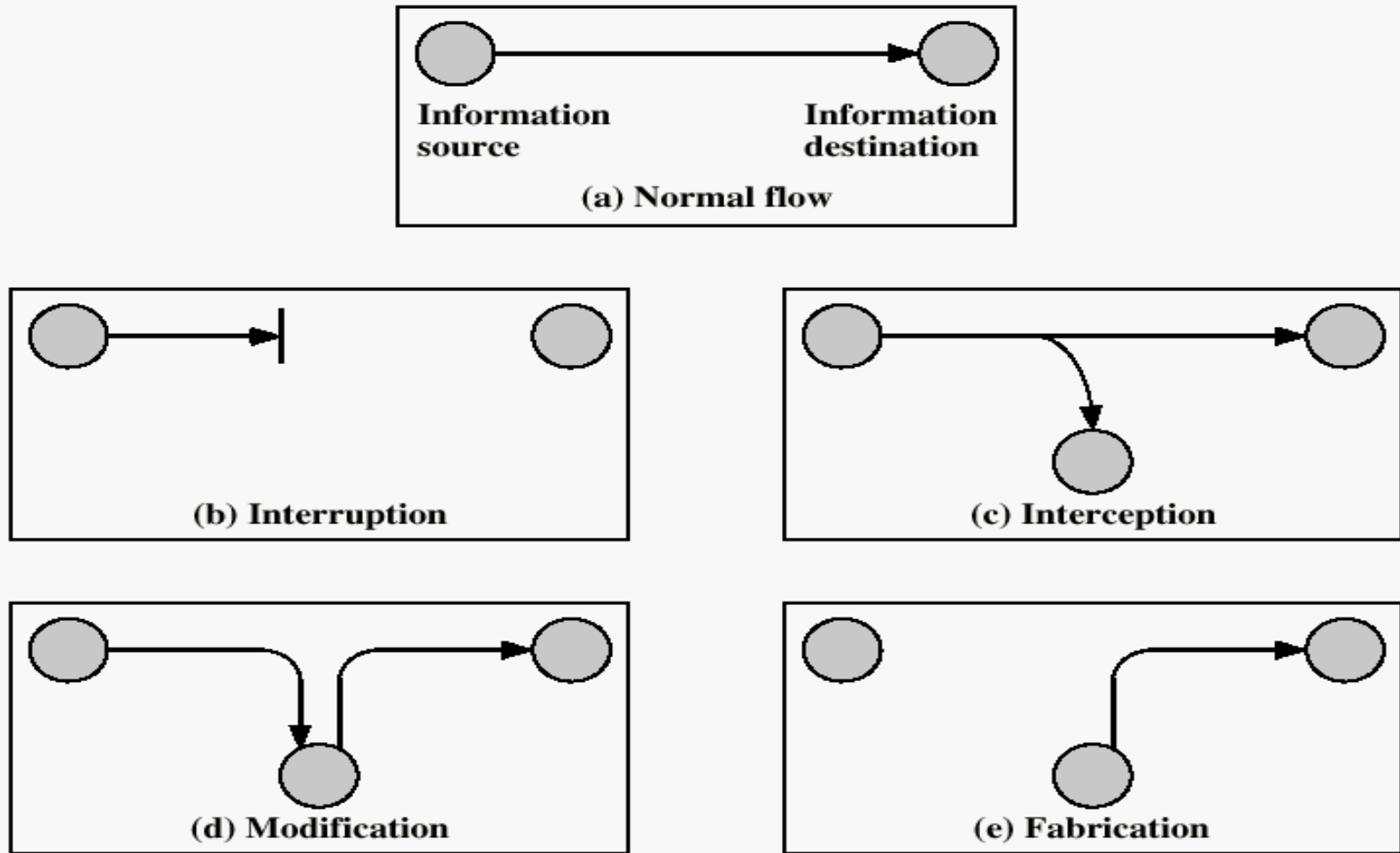


Figure 1.1 Security Threats

SECURITY ATTACKS

1. **Interruption:** This is an attack on **availability**
2. **Interception:** This is an attack on **confidentiality**
3. **Modification:** This is an attack on **integrity**
4. **Fabrication:** This is an attack on **authenticity**

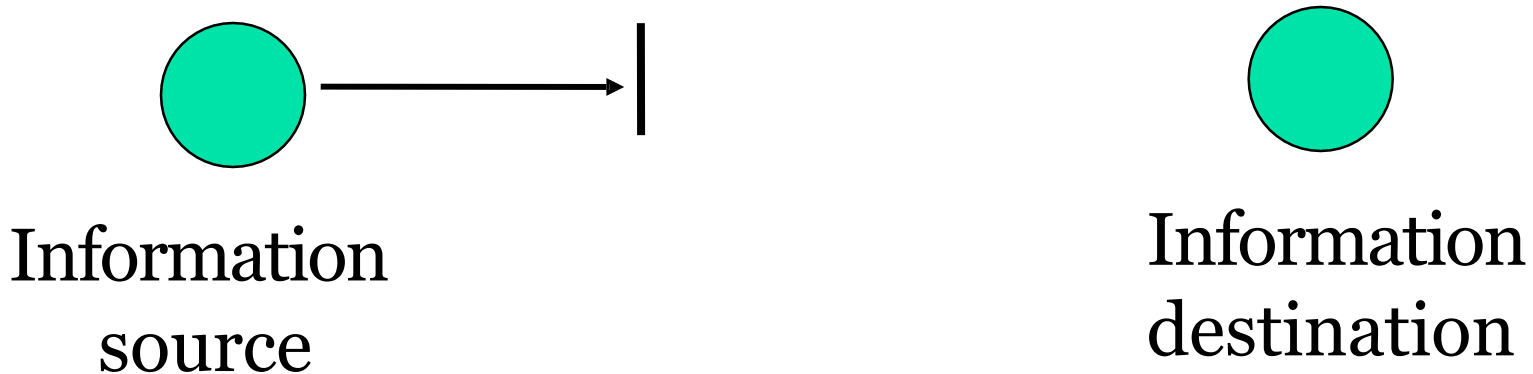
SECURITY ATTACKS



Normal Flow

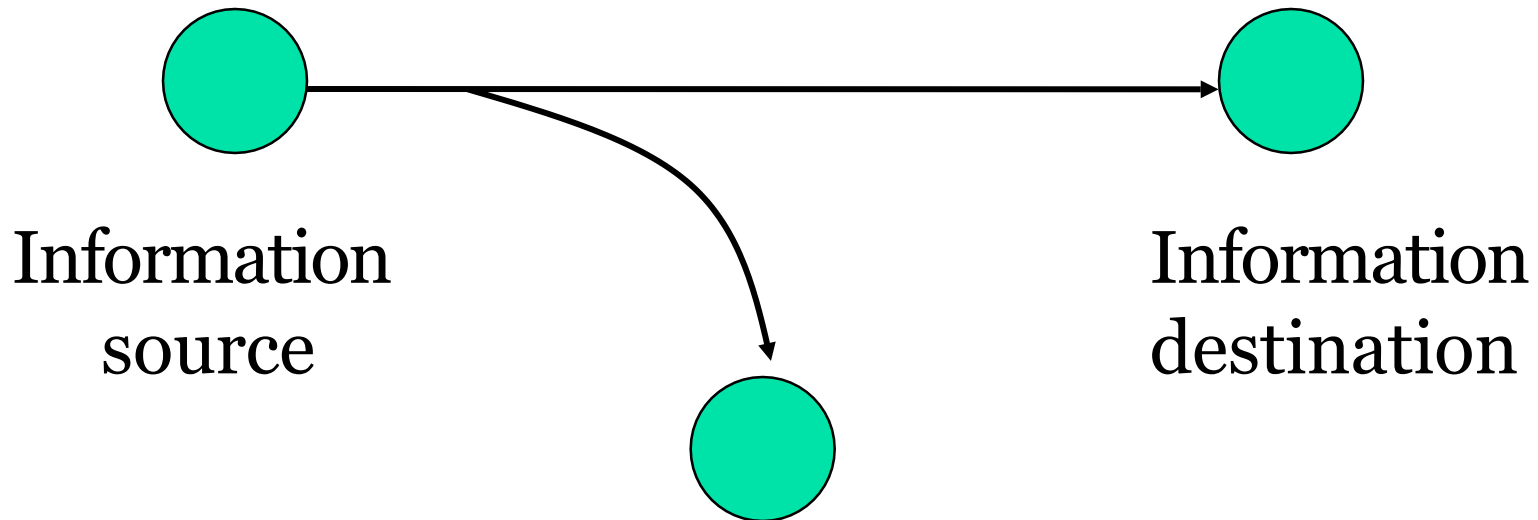
SECURITY ATTACKS

- **Interruption:** This is an attack on **availability**
 - ✓ **Approach:** Destruction of hardware, physical damages to communication links, Disrupting traffic (introduction to noise), erase of a program or a file, DoS attacks



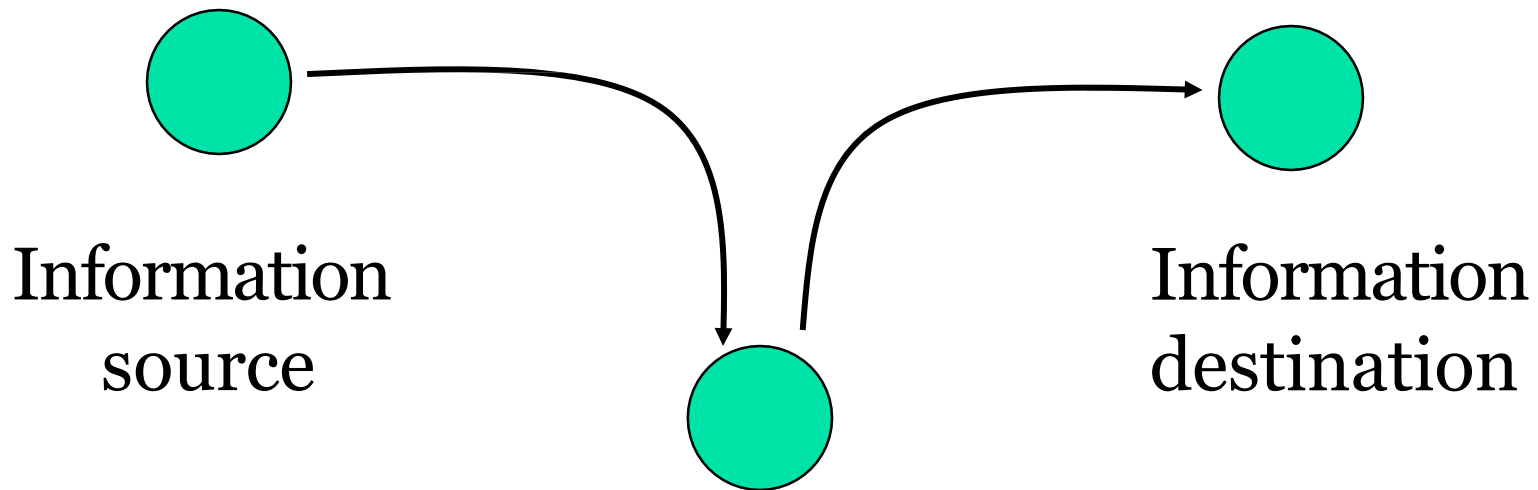
SECURITY ATTACKS

- **Interception:** This is an attack on **confidentiality**
 - ✓ **Approach:** Eavesdropping over a communication line, Link monitoring, packet capturing, system compromisation.



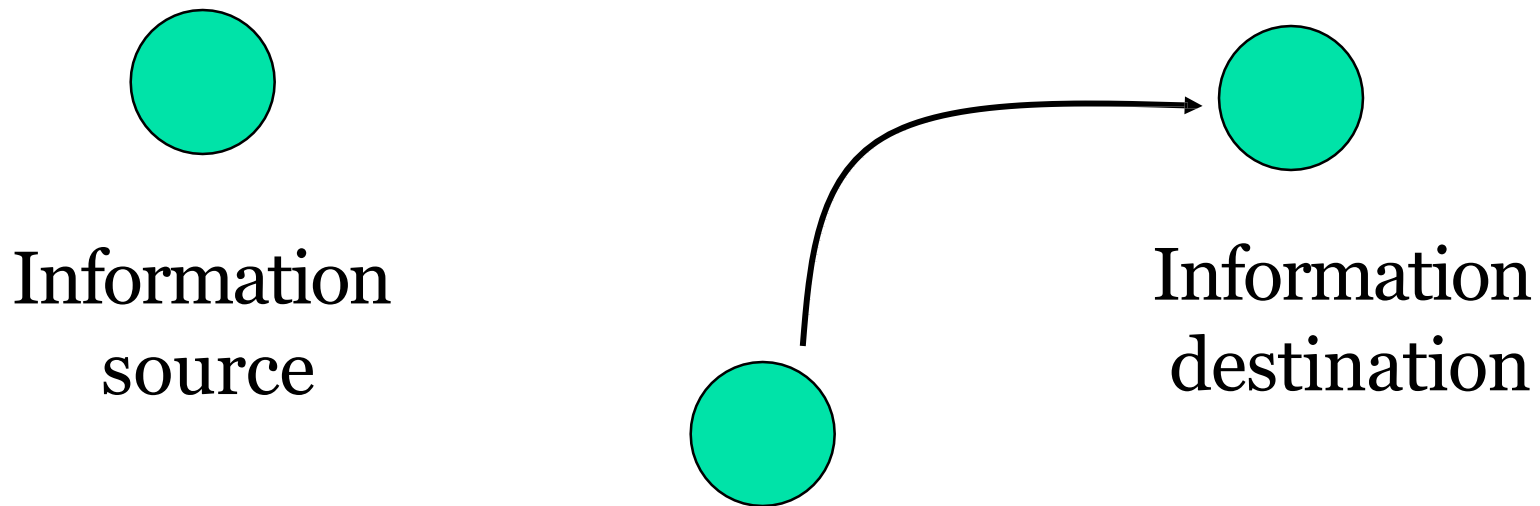
SECURITY ATTACKS

- **Modification:** This is an attack on **integrity**
 - ✓ **Approach:** Corrupting transmitted data or tampering with it before it reaches its destination. E.g. Changing a record in database.



SECURITY ATTACKS

- **Fabrication:** This is an attack on **authenticity**
 - ✓ **Approach:** Faking data as if it were created by a legitimate and authentic party. E.g. Adding a new record to a database, insertion of new network packet.



PASSIVE VS. ACTIVE ATTACKS

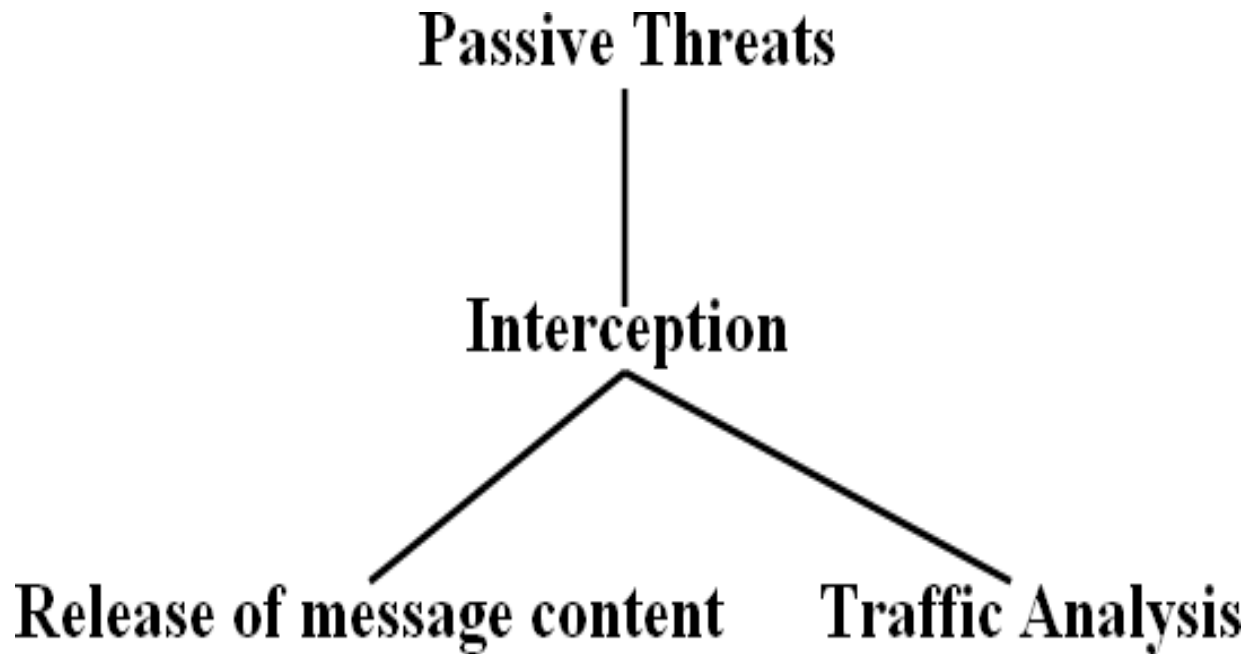
- Security attacks are usually classified as:
 1. **Passive Attacks**
 2. **Active Attacks**

ATTACKS: **PASSIVE ATTACKS**

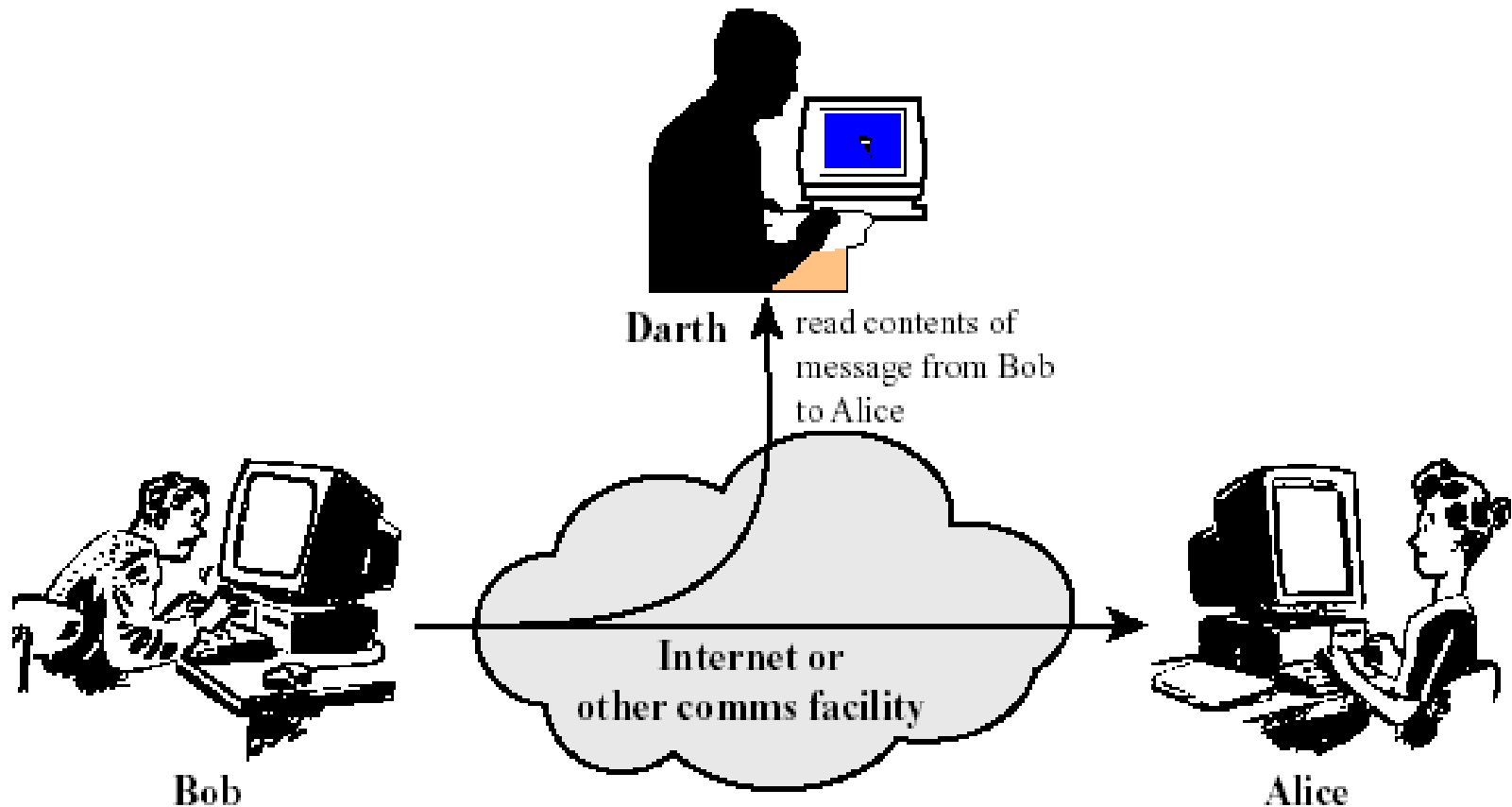
- **Passive Attacks:** Attempts to learn or make use of information from the system, but does not affect system resources.
- **Interception: Goal** is to obtain information
 - ✓ No modification of content or fabrication
- **Two types of attacks**
 1. **Traffic analysis**
 - ✓ Detects the source and destination.
 - ✓ Frequency of transmission and length of messages.
 2. **Release of message content**
 - ✓ To gain personal advantages
 - ✓ Blackmailing parties involved in communication

ATTACKS: **PASSIVE ATTACKS**

- Hard to detect
- Prevention is the better than detection.

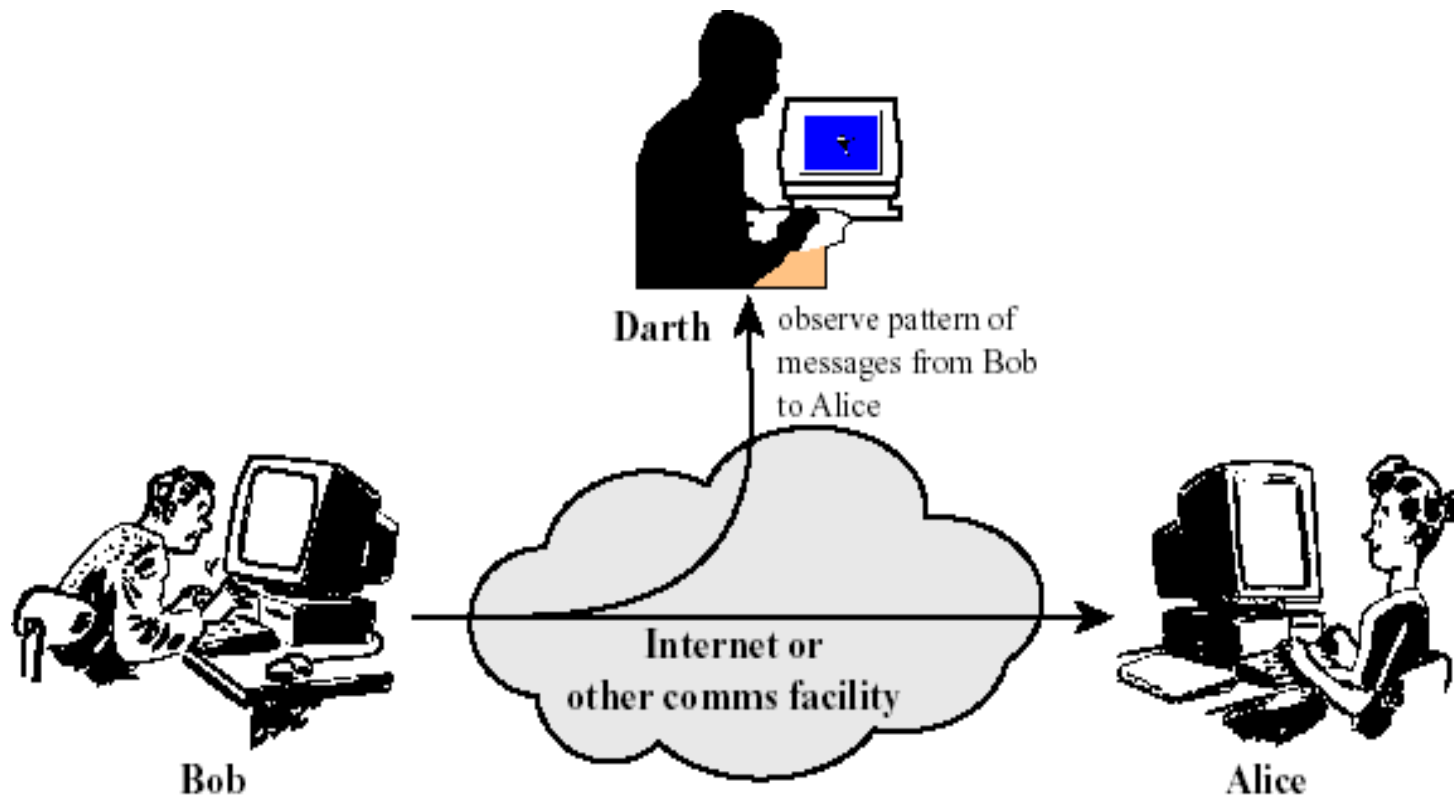


PASSIVE ATTACKS



(a) Release of message contents

PASSIVE ATTACKS



(b) Traffic analysis

ATTACKS: ACTIVE ATTACKS

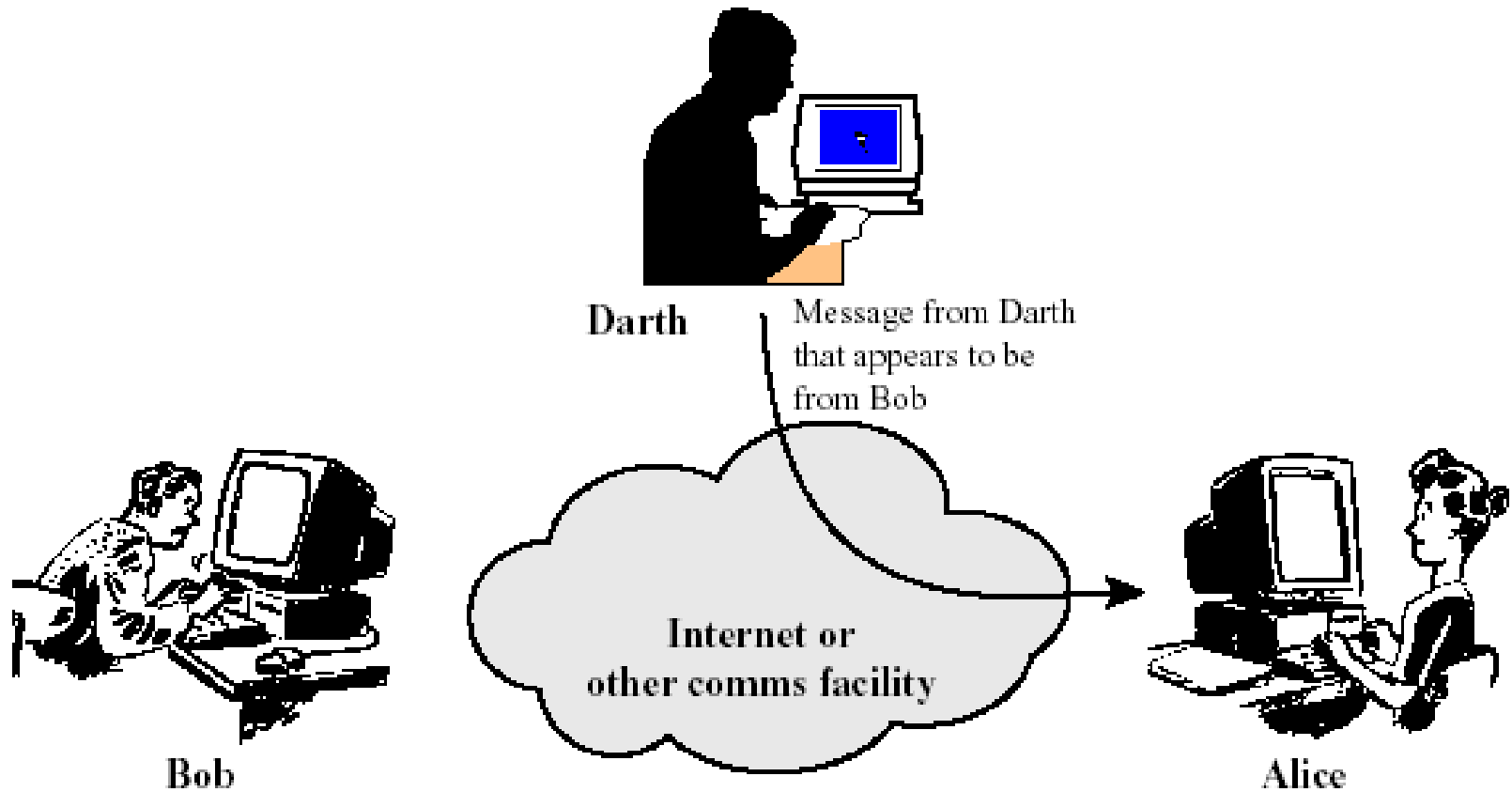
- **Active Attacks:** Attempts to alter system resources or affect their operation.
- Interruption, modification and fabrication
 - ✓ Modification of content and/or participation in communication.
- **Four categories**
 1. **Masquerading**
 - ✓ Pretends to be some one else
 2. **Replay** or **retransmit**
 - ✓ Retransmission of passive captured data
 3. **Modification** the content in transit.
 4. **Deny of Service (DoS) attack**

ATTACKS: ACTIVE ATTACKS

- Easily detectable
- Harder to prevent
- Can cover from destruction

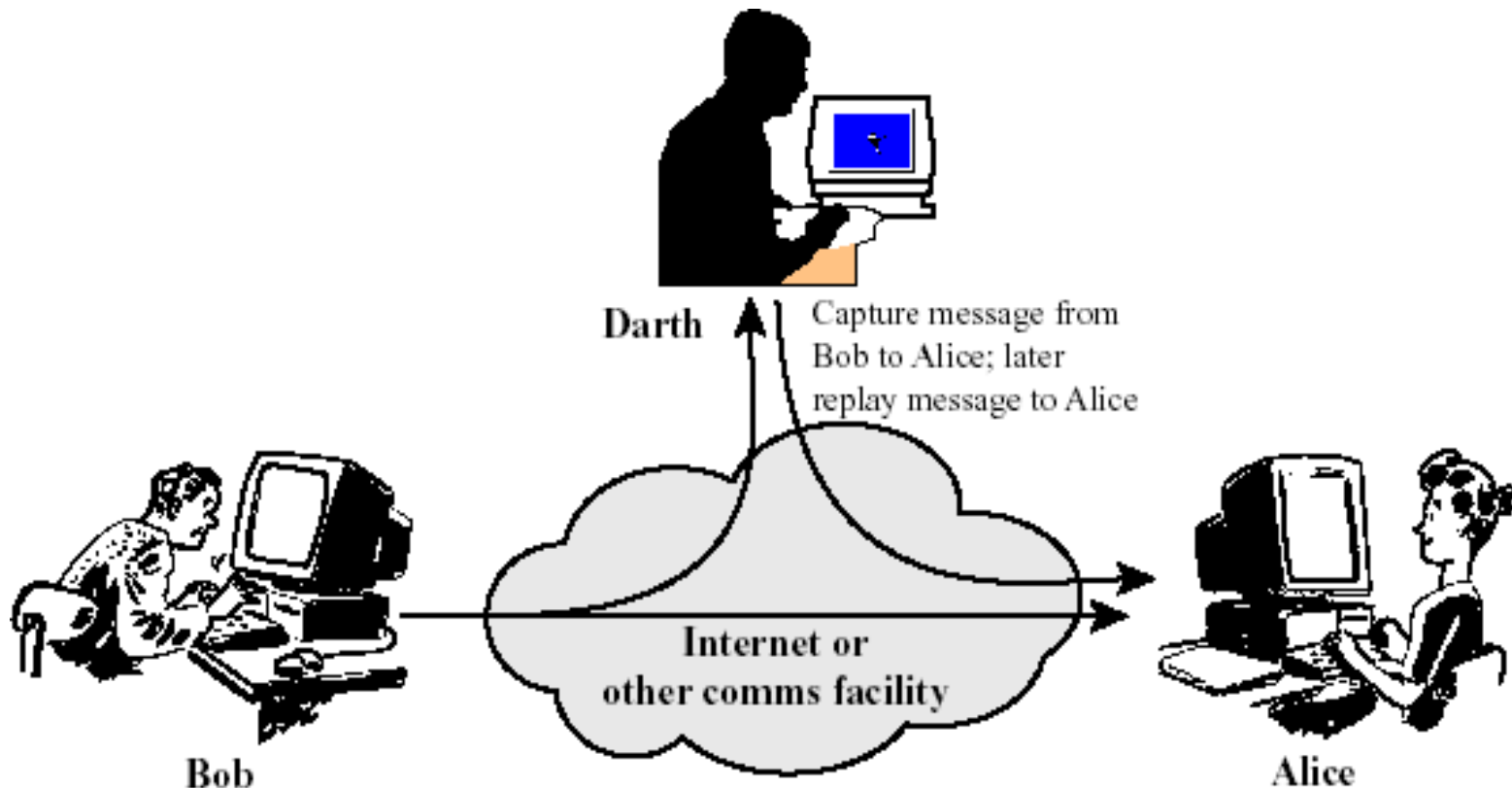


ACTIVE ATTACKS



(a) Masquerade

ACTIVE ATTACKS



(b) Replay

Summary of Passive and Active Threats

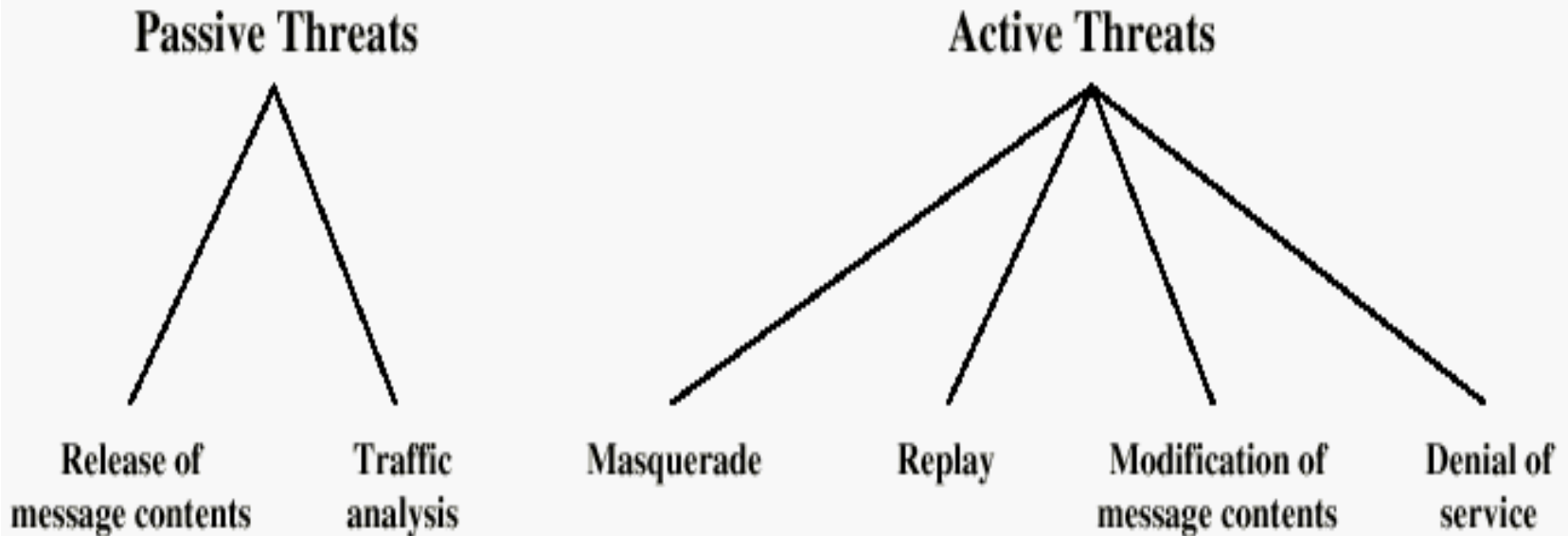


Figure 1.2 Active and Passive Security Threats

ESSENTIAL TERMINOLOGIES

- **A replay attack** attempts to gain access by repeating legitimate traffic that was sniffed and captured in a previous session.
- **Denial of service attack**, is an attempt to make a computer resource unavailable to the intended users
- **Masquerade attack**, the attacker assumes the identity of another authorized user of a system in order to gain access to it or to gain greater privileges than they are authorized for.

(2) SECURITY MECHANISM

- Feature designed to detect, prevent, or recover from a security attack
- No single mechanism that will support all services required
- However one particular element underlies many of the security mechanisms in use:
 - ✓ **Cryptographic techniques**
 - ✓ E.g. **encryption** used for authentication

(3) SECURITY SERVICES

- Enhance security of data processing systems and information transfers of an organization.
- Are intended to **counter security attacks**.
- Use one or more **security mechanisms**.
- **6 categories:**

1. **Confidentiality**

2. **Authentication**

3. **Integrity**

4. **Non-Repudiation**

5. **Access Control**

6. **Availability**

SECURITY SERVICES

- **Authentication:** The assurance that the communicating entity is the one that it claims to be.
- **Access control:** The prevention of unauthorized use of a resource (i.e., this service **controls** who can have access to a resource, under what conditions access can occur, and what those accessing the resource are allowed to do).
- **Data confidentiality:** The protection of data from unauthorized disclosure.
- **Data integrity:** The assurance that data received are exactly as sent by an authorized entity (i.e., contain no modification, insertion, deletion, or replay).

SECURITY SERVICES

- **Non-repudiation:** Provides protection against denial by one of the entities involved in a communication of having participated in all or part of the communication.
- **Availability service:** The property of a system or a system resource being accessible and usable upon demand by an authorized system entity, according to performance specifications for the system (i.e., a system is available if it provides services according to the system design whenever users request them).

MECHANISMS AND SERVICES

- A **security policy** is a statement of what is and what is not allowed.
- A **security mechanism** is a means to provide a security service.
 - ✓ E.g. encryption, cryptographic protocols
- A **security service** is a measure to address a security threat.
 - ✓ E.g. **authenticate** individuals to prevent unauthorized access
- **Security services** implement security **policies** and are implemented by security **mechanisms**.

HOME WORK 1

- What is the **OSI security architecture**?
- What is the difference between **authenticity** and **non-repudiation**.
- What is the difference between **Security Mechanisms** and **Security Services**.

NEXT LECTURE

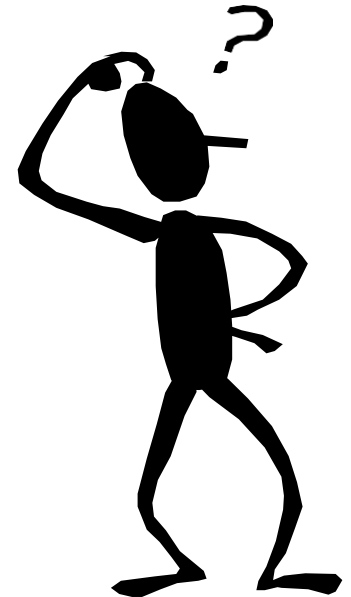
- **LECTURE 02**

- ✓ **MONDAY: 06/11/2023 (NEXT Week)**

- ✓ **Tutorial hour**

THANK YOU

END



ET 8202: LECTURE 01